

BREACHFOMRUMS

-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA512

Hello everyone,

We would like to provide an update on recent events over the past two weeks. In or around April 15, we received confirmation of information that we had been suspecting since day 1 - a MyBB 0day. This confirmation came through trusted contacts that we are in touch with, which revealed that our forum (breachforums.st) is subject to infiltration by various agencies and other global law enforcement bodies.

Upon learning of this, we immediately took action by shutting down our infrastructure and initiating our incident response procedures. Our findings indicate that, fortunately, our infrastructure were NOT compromised, and no data was infiltrated. Subsequently, we began auditing the MyBB source code and we believe we have identified the PHP exploit.

We would like to sincerely apologize to the community and our staff for the lack of communication and transparency during this time. As you can appreciate, given the nature of our work, our priority had to be securing the safety of our infrastructure, staff, and the community above all else. Now that our incident response is complete, we are actively working on a complete rewrite of the forum backend.

Finally, we would like to address the growing number of BreachForums clones and the various rumors circulating about us and our administrators. We want to reassure everyone that no members of our team have been arrested, and as previously mentioned, our infrastructure remains secure. We strongly advise against engaging with these BreachForums clones, as they are likely honeypots and cannot be trusted. Please exercise caution and be discerning in whom you trust and which services you use.

Thank you for your understanding and continued support.

Best regards,
BreachForums Administration

DDOS ATTACK

- Un ataque DDoS (Denegación de Servicio Distribuido) busca sobrecargar un servicio online, como un sitio web, con tráfico malicioso desde múltiples fuentes coordinadas.
- Esto lo hace inaccesible para los usuarios legítimos.

TIPOS

Existen varios tipos, como:

- ataques volumétricos (inundación de tráfico),
- ataques de protocolo (explotan debilidades en la comunicación)
- ataques a la capa de aplicación (dirigidos a funcionalidades específicas del software).

LA CLAVE

- La clave es la distribución del ataque, lo que dificulta el bloqueo de las fuentes individuales.
- El objetivo final es interrumpir la disponibilidad del servicio atacado.

EL GRUPO DARK STORM

- Pro-Palestinian cyber-attack group specializing in distributed denial-of-service (DDoS) attacks.
- They offer DDoS-for-hire services and breach databases

CÓMO LO HACEN?

- Alquilar direcciones IP de varias regiones
- Utilizar grandes botnets compuestas por miles (o incluso cientos de miles) de dispositivos comprometidos en todo el mundo
- Enmascarar sus ubicaciones reales a través de múltiples proxies y servicios VPN

DDOS ATTACK

RESEARCH

SECURITY

MARCH 11, 2025

Dark Storm Team Claims Responsibility for Cyber Attack on X Platform – What It Means for the Future of Digital Security



By Check Point Research

- <https://check-host.net/check-report/23e27469k58a>

AYER - SE CORTÓ LA LUZ EN ESPAÑA, PORTUGAL, FRANCIA Y ALEMANIA



AYER - SE CORTÓ LA LUZ EN ESPAÑA, PORTUGAL, FRANCIA Y ALEMANIA



AYER - SE CORTÓ LA LUZ EN ESPAÑA, PORTUGAL, FRANCIA Y ALEMANIA



AYER - SE CORTÓ LA LUZ EN ESPAÑA, PORTUGAL, FRANCIA Y ALEMANIA



AYER - SE CORTÓ LA LUZ EN ESPAÑA, PORTUGAL, FRANCIA Y ALEMANIA



QUÉ PASÓ? QUIÉN FUE?

Red Eléctrica Española ha afirmado que, hasta el momento, "ningún agente externo ha interferido para provocar el shock eléctrico" que afectó al sistema en España.

Por su parte, en declaraciones a la cadena portuguesa *RTP 3*, el ministro Adjunto y de Cohesión Territorial de Portugal, **Manuel Castro Almeida**, afirmó que existe la posibilidad de que el apagón sea producto de un **ciberataque**, aunque destacó que la información disponible todavía es limitada y no confirmada.

NADIE SABE....



DARK STORM TEAM SE LO ADJUDICA



OTROS CASOS CONOCIDOS

- El 23 de diciembre de 2016 la región de Ivano-Frankivsk, en el suroeste de Ucrania, sufrió un apagón como consecuencia de un ciberataque.
- 2015 un ciberataque más sofisticado volvió a provocar un apagón que afectó a residentes de Kiev, también en Ucrania. Mumbai,

OTROS CASOS CONOCIDOS (CONT)

- Dinamarca (noviembre 2023): Ciberataques coordinados afectaron al sector energético, resultando en robos de datos pero sin apagones.
- En junio de 2019 un gran apagón afectó a 48 millones de personas en Argentina y Uruguay.
- Y luego, Stuxnet. Lo que sabemos es cómo supuestamente EEUU e Israel crearon el malware Stuxnet en la segunda mitad de la década de 2000.

A02-2021 FALLAS CRIPTOGRÁFICAS

- Subiendo una posición al número 2.
- Anteriormente conocido como Exposición de datos sensibles.
 - *Fallas Criptográficas* es más amplio.
- La atención se centra en fallas relacionadas con el uso de la criptografía (o la falta de este), lo que a menudo conduce a la exposición de datos sensibles.

A02-2021 FALLAS CRIPTOGRÁFICAS

Las CWE incluidas son:

- CWE-259: Uso de contraseña en código fuente
- CWE-327: Algoritmo criptográfico vulnerado o inseguro
- CWE-331: Entropía insuficiente.

https://owasp.org/Top10/A02_2021-Cryptographic_Failures/#list-of-mapped-cwes

A02-2021 FALLAS CRIPTOGRÁFICAS

- Muchas aplicaciones no protegen correctamente los datos sensibles, como ser tarjetas de crédito, datos económicos y datos de autenticación.
- Los datos sensibles deben tener protección extra como ser encriptación, tanto cuando están almacenados o en tránsito cuando se intercambia con el browser del cliente.

A02-2021 FALLAS CRIPTOGRÁFICAS

- Las aplicaciones frecuentemente utilizan diseños pobres de criptografía, algoritmos de cifrado inadecuados, errores serios en el uso de criptografía fuerte.
- Vulnerabilidades:
 - No encriptar datos sensibles
 - Usar algoritmos de cifrado caseros.
 - Usar algoritmos fuertes de manera no segura.
 - Usar algoritmos cuya debilidad ya fue probada (MD5, SHA-1, RC3, RC4)
 - Harcodear claves y guardarlas en medios no protegidos

A02-2021 FALLAS CRIPTOGRÁFICAS

- En lugar de atacar la criptografía, los atacantes roban claves, ejecutan ataques Man in the Middle o roban datos en texto plano del servidor, en tránsito, o desde el cliente.
- Se requiere un ataque manual pero pueden utilizarse bases de datos con hashes que han sido hechas públicas para obtener las contraseñas originales utilizando algún mecanismo de crackeo por ejemplo utilizando GPUs.

A02-2021 FALLAS CRIPTOGRÁFICAS

- En los últimos años, este ha sido el ataque de mayor impacto.
- El error más común es simplemente no cifrar los datos sensibles.
- Cuando se emplea criptografía, es común la generación y gestión de claves, algoritmos, cifradores y protocolos débiles.
- En particular algoritmos débiles de hashing para el almacenamiento de contraseñas.

A02-2021 FALLAS CRIPTOGRÁFICAS

- Los fallos con frecuencia comprometen datos que deberían estar protegidos.
- Típicamente, esta información incluye Información Personal Sensible (PII) como registros de salud, datos personales, credenciales y tarjetas de crédito, que a menudo requieren mayor protección.

A02-2021 - LA APLICACIÓN ES VULNERABLE?

- Lo primero es determinar las necesidades de protección de los datos en tránsito y en almacenamiento.
- Por ejemplo, contraseñas, números de tarjetas de crédito, registros médicos, información personal y datos sensibles del negocio requieren protección adicional.
- Si se envía información confidencial a través de Internet sin seguridad en las comunicaciones, un atacante en una conexión inalámbrica compartida podría ver y robar los datos de otro usuario.
- Además, un atacante podría usar SQL Injection para robar contraseñas y otras credenciales de una base de datos de aplicaciones y exponer esa información al público.

A02-2021 - LA APLICACIÓN ES VULNERABLE?

- Tener en cuenta [Ley de Protección de los Datos Personales Ley 25.326](#)
 - **Datos personales:** Información de cualquier tipo referida a personas físicas.
 - **Datos sensibles:** Datos personales que revelan origen racial/étnico, opiniones políticas/filosóficas/morales, religion, afiliación sindical, datos de salud, etc.

A02-2021 - LA APLICACIÓN ES VULNERABLE?

- Para los datos sensibles hay que pensar en:
 - ¿Algunos de esos datos se guardan en plano? → ¿Considerando backups?
 - ¿Estos datos se transmiten como texto plano? ¿Ya sea Interna o externamente?
 - ¿Se usan algoritmos de cifrado viejos, débiles?
- El manejo de claves de cifrado: ¿Cómo se generan? ¿Cómo se administran? ¿Se rotan? ¿Como se recuperan contraseñas olvidadas? ¿Ante un compromiso existe procedimiento de respuesta?

A02-2021 - EJEMPLOS DE ESCENARIOS DE ATAQUE

- **Escenario #1:**
 - Una aplicación cifra números de tarjetas de crédito en una base de datos utilizando su cifrado automático.
 - Sin embargo, estos datos son automáticamente descifrados al ser consultados, permitiendo que, si existe un error de inyección SQL se obtengan los números de tarjetas de crédito en texto plano.

A02-2021 - EJEMPLOS DE ESCENARIOS DE ATAQUE

- **Escenario #2:**
 - Un sitio web no utiliza o no fuerza el uso de TLS para todas las páginas, o utiliza cifradores débiles.
 - Un atacante monitorea el tráfico de la red (por ejemplo en una red Wi-Fi insegura), degrada la conexión de HTTPS a HTTP e intercepta los datos, robando las cookies de sesión del usuario.
 - El atacante reutiliza estas cookies y secuestra la sesión del usuario (ya autenticado), accediendo o modificando datos privados.
 - También podría alterar los datos enviados.

A02-2021 - EJEMPLOS DE ESCENARIOS DE ATAQUE

- **Escenario #3:**
 - Se utilizan hashes simples o hashes sin SALT para almacenar las contraseñas de los usuarios en una base de datos.
 - Una falla en la carga de archivos permite a un atacante obtener las contraseñas. Todas las contraseñas sin SALT pueden ser expuestas usando hashes precalculados.

A02-2021: RIESGO

					
App. Específica	Explotabilidad: 2	Prevalencia 3	Detectabilidad: 2	Técnico: 3	¿Negocio?
En lugar de atacar la criptografía, los atacantes roban claves, ejecutan ataques <i>Man in the Middle</i> o roban datos en texto plano del servidor, en tránsito, o desde el cliente. Se requiere un ataque manual pero pueden utilizarse bases de datos con <i>hashes</i> que han sido hechas públicas para obtener las contraseñas originales utilizando GPUs.		En los últimos años, este ha sido el ataque de mayor impacto. El error más común es simplemente no cifrar los datos sensibles. Cuando se emplea criptografía, es común la generación y gestión de claves, algoritmos, cifradores y protocolos débiles. En particular algoritmos débiles de <i>hashing</i> para el almacenamiento de contraseñas. Para los datos en tránsito las debilidades son fáciles de detectar, mientras que para los datos almacenados es muy difícil. Ambos tienen una explotabilidad muy variable.		Los fallos con frecuencia comprometen datos que deberían estar protegidos. Típicamente, esta información incluye Información Personal Sensible (PII) como registros de salud, datos personales, credenciales y tarjetas de crédito, que a menudo requieren mayor protección, según lo definido por las leyes o reglamentos como el PIBR de la UE o las leyes locales de privacidad.	

A02-2021: REFERENCIAS

- OWASP Proactive Controls: Protect Data Everywhere
- OWASP Application Security Verification Standard (V7, 9, 10)
- OWASP Cheat Sheet: Transport Layer Protection
- OWASP Cheat Sheet: User Privacy Protection
- OWASP Cheat Sheet: Password and Cryptographic Storage
- OWASP Cheat Sheet: HSTS
- OWASP Testing Guide: Testing for weak cryptography

C8: CONTROL PROACTIVO: PROTEJA LOS DATOS EN TODAS PARTES

<https://owasp.org/www-project-proactive-controls/v3/en/c8-protect-data-everywhere>

A02-2021 - CLASIFICACIÓN DE LOS DATOS

- Es fundamental clasificar los datos en un sistema y determinar a qué nivel de sensibilidad pertenece cada dato.
- Luego, cada categoría de datos se puede asignar a las reglas de protección necesarias para cada nivel de sensibilidad.
- Por ejemplo:
 - la información de marketing público que no es confidencial puede clasificarse como datos públicos que se pueden colocar en el sitio web público.
 - pero los números de tarjetas de crédito pueden clasificarse como datos de usuario privados que pueden necesitar ser encriptados mientras están almacenados o en tránsito.

A02-2021 - CIFRADO DE DATOS EN TRÁNSITO

- Al transmitir datos confidenciales a través de cualquier red, se debe considerar la seguridad de las comunicaciones de extremo a extremo (o cifrado en tránsito) de algún tipo.
- TLS es, con mucho, el protocolo criptográfico más común y ampliamente admitido para la seguridad de las comunicaciones.
 - Es utilizado por muchos tipos de aplicaciones (web, servicio web, móvil) para comunicarse a través de una red de forma segura.
 - TLS debe configurarse correctamente en una variedad de formas para defender adecuadamente las comunicaciones seguras.
- El beneficio principal de la seguridad de la capa de transporte es la protección de los datos de la aplicación web contra la divulgación y modificación no autorizadas cuando se transmite entre clientes (navegadores web) y el servidor de aplicaciones web, y entre el servidor de aplicaciones web y el back-end y otros no basados en navegador

C8 - CIFRAR DATOS EN REPOSO

- La primera regla de la gestión de datos confidenciales es evitar almacenar datos confidenciales cuando sea posible.
- **LO QUE NO TENÉS NO TE LO PUEDEN ROBAR**
- Si debe almacenar datos confidenciales, asegúrese de que estén protegidos criptográficamente de alguna manera para evitar la divulgación y modificación no autorizadas.

C8 - CIFRAR DATOS EN REPOSO

- La criptografía es uno de los temas más avanzados de seguridad de la información, y uno cuya comprensión requiere la mayor educación y experiencia.
- Es difícil hacerlo bien porque hay muchos enfoques para el cifrado, cada uno con ventajas y desventajas que los arquitectos y desarrolladores de soluciones web deben comprender a fondo.
- Además, la investigación seria en criptografía se basa típicamente en matemáticas avanzadas y teoría de números, lo que constituye una seria barrera de entrada.

C8 - CIFRAR DATOS EN REPOSO

- En lugar de crear una capacidad criptográfica desde cero, se recomienda encarecidamente que se utilicen soluciones abiertas y revisadas por pares, como el proyecto [Google Tink](#), [Libsodium](#) y la capacidad de almacenamiento seguro integrada en muchos frameworks de software y servicios en la nube.

C8 - CIFRAR DATOS EN REPOSO

- Las aplicaciones móviles corren un riesgo particular de fuga de datos porque los dispositivos móviles se pierden o son robados con regularidad, pero contienen datos confidenciales.
- Como regla general, solo los datos mínimos requeridos deben almacenarse en el dispositivo móvil.
- Pero si debe almacenar datos confidenciales en un dispositivo móvil, entonces los datos confidenciales deben almacenarse dentro del directorio de almacenamiento de datos específico de cada sistema operativo móvil.
- En Android, será el [almacén de claves de Android](#) y en iOS será el llavero de iOS.

C8 - CIFRAR DATOS EN REPOSO

- Las aplicaciones contienen numerosos "secretos" necesarios para las operaciones de seguridad.
- Estos incluyen certificados, contraseñas de conexión SQL, credenciales de cuentas de servicios de terceros, contraseñas, claves SSH, claves de cifrado y más.
- La divulgación o modificación no autorizada de estos secretos podría llevar a un compromiso total del sistema.

C8 - CIFRAR DATOS EN REPOSO

- Al administrar los secretos de la aplicación, tenga en cuenta lo siguiente.
- No almacene secretos en código, archivos de configuración ni los pase a través de variables de entorno.
- Guarde las claves y sus otros secretos de nivel de aplicación en una bóveda de secretos como [KeyWhiz](#) o el proyecto [Vault de Hashicorp](#) o [Amazon KMS](#) para proporcionar almacenamiento seguro y acceso a secretos de nivel de aplicación en tiempo de ejecución.

TRANSPORT LAYER SECURITY

TLS

- Cuando se implementa correctamente, TLS puede proporcionar una serie de beneficios de seguridad:
 - **Confidencialidad:** protección contra que un atacante lea el contenido del tráfico.
 - **Integridad:** protección contra un atacante que modifique el tráfico.
 - **Prevención de reproducción:** protección contra un atacante que reproduce solicitudes en el servidor.
 - **Autenticación:** permite al cliente verificar que está conectado al servidor real (tenga en cuenta que la identidad del cliente no se verifica a menos que se utilicen certificados de cliente).

SSL VS TLS

- Secure Socket Layer (SSL) fue el protocolo original que se utilizó para proporcionar cifrado para el tráfico HTTP, en forma de HTTPS.
- Hubo dos versiones de SSL publicadas: las versiones 2 y 3, ambas tienen serias debilidades criptográficas y ya no deberían usarse.
- Por varias razones, la siguiente versión del protocolo (efectivamente SSL 3.1) se denominó Transport Layer Security (TLS) versión 1.0.
- Posteriormente se lanzaron las versiones 1.1, 1.2 y 1.3 de TLS.
- Los términos "SSL", "SSL / TLS" y "TLS" se usan indistintamente con frecuencia y, en muchos casos, se usa "SSL" cuando se hace referencia al protocolo TLS más moderno.

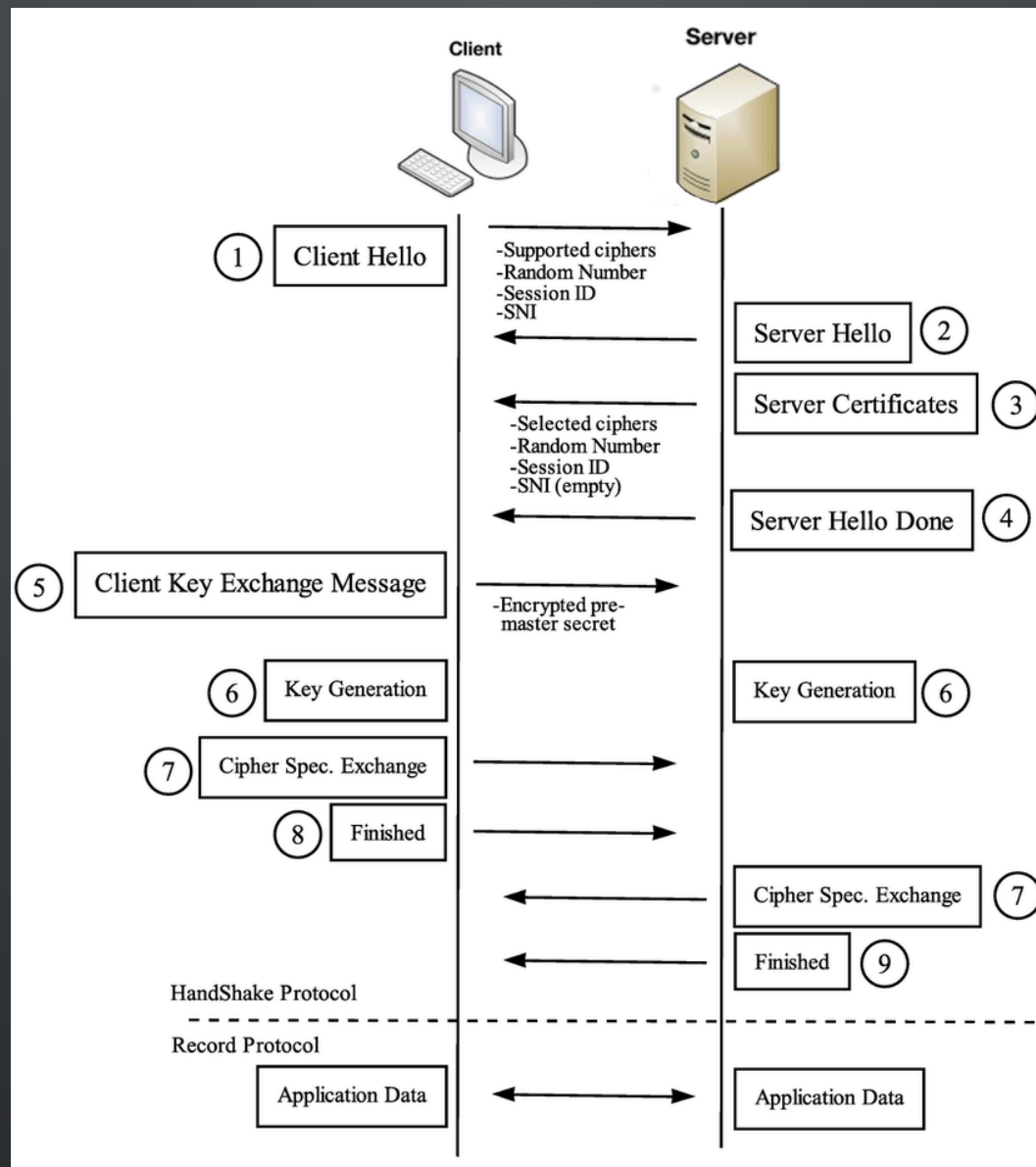
TLS: TLS HANDSHAKE

- 1- Client Hello: el cliente inicia el protocolo de enlace enviando un mensaje de "saludo" al servidor.
 - El mensaje incluirá qué versión de TLS admite el cliente, los conjuntos de cifrado admitidos y una cadena de bytes aleatorios conocida como "cliente aleatorio".
- 2- Server Hello: en respuesta al mensaje de saludo del cliente, el servidor envía un mensaje que contiene el certificado SSL del servidor, el conjunto de cifrado elegido por el servidor y el "servidor aleatorio", otra cadena aleatoria de bytes que genera el servidor.
- 3- The premaster secret: el cliente envía una cadena aleatoria de bytes más, el "premaster secret".
 - El secreto de premaster está encriptado con la clave pública y el servidor solo puede desencriptarlo con la clave privada. (El cliente obtiene la clave pública del certificado SSL del servidor).

TLS: TLS HANDSHAKE

- 4- Clave privada utilizada: el servidor descifra el secreto de premaster.
- 5- Claves de sesión creadas: tanto el cliente como el servidor generan claves de sesión desde el cliente aleatorio, el servidor aleatorio y el secreto del premaster.
 - Deberían llegar a los mismos resultados.
- 6- El cliente está listo: el cliente envía un mensaje "terminado" que está encriptado con una clave de sesión.
- 7- El servidor está listo: el servidor envía un mensaje "terminado" cifrado con una clave de sesión.
- 8- Cifrado simétrico seguro logrado: el protocolo de enlace se completa y la comunicación continúa utilizando las claves de sesión.

TLS: TLS HANDSHAKE



TLS: PROTOCOLOS FUERTES

- Los protocolos SSL tienen una gran cantidad de debilidades y no deben usarse en ninguna circunstancia.
- Los servidores web de propósito general solo deben admitir TLS 1.2 y TLS 1.3, con todos los demás protocolos deshabilitados.

Cuando se sabe que un servidor web debe admitir clientes legacy con navegadores no compatibles o inseguros (como Internet Explorer 10), puede ser necesario habilitar TLS 1.0 para brindar soporte.

TLS: CERTIFICADOS

- Use claves fuertes y protéjalas
- La clave privada utilizada para generar la clave de cifrado debe ser lo suficientemente fuerte para la vida útil de la clave privada y el certificado correspondiente.
- La mejor práctica actual es seleccionar un tamaño de clave de al menos 2048 bits.
- La clave privada también debe protegerse del acceso no autorizado mediante permisos del sistema de archivos y otros controles técnicos y administrativos.

TLS: CERTIFICADOS

- Utilice algoritmos de hash criptográficos potentes
- Los certificados deben usar SHA-256 para el algoritmo hash, en lugar de los algoritmos MD5 y SHA-1 más antiguos.
- Estos tienen una serie de debilidades criptográficas y los navegadores modernos no confían en ellos.
- Recuerden el ejemplo del barco y el avión!

TLS: DOMINIOS

- El nombre de dominio (o subject) del certificado debe coincidir con el nombre completo del servidor que presenta el certificado.
- Históricamente, esto se almacenaba en el atributo commonName (CN) del certificado.
- Sin embargo, las versiones modernas de Chrome ignoran el atributo CN y requieren que el FQDN esté en el atributo subjectAlternativeName (SAN).
- Por motivos de compatibilidad, los certificados deben tener el FQDN principal en la CN y la lista completa de FQDN en la SAN.

TLS: DOMINIOS

- Además, al crear el certificado, se debe tener en cuenta lo siguiente:
 - Considere si también debe incluirse el subdominio "www".
 - No incluya nombres de host no calificados.
 - No incluya direcciones IP.
 - No incluya nombres de dominio internos en certificados externos.
 - Si se puede acceder a un servidor mediante FQDN internos y externos, configúrelo con varios certificados.

TLS: DOMINIOS WILDCARD

- Los certificados wildcard pueden ser convenientes, sin embargo, violan el principio de mínimo privilegio, ya que un solo certificado es válido para todos los subdominios de un dominio (como *.example.org).
- Cuando varios sistemas comparten un certificado comodín, aumenta la probabilidad de que la clave privada del certificado se vea comprometida, ya que la clave puede estar presente en varios sistemas.
- Además, el valor de esta clave aumenta significativamente, lo que la convierte en un objetivo más atractivo para los atacantes.

TLS: AUTORIDAD DE CERTIFICACIÓN (CA)

- Con el fin de ser de confianza para los usuarios, los certificados deberán ser firmados por una autoridad de certificados de confianza (CA).
- Para las aplicaciones orientadas a Internet, esta debe ser una de las CA reconocidas y de confianza automática para los sistemas operativos y navegadores.
- LetsEncrypt CA proporciona certificados SSL validados de dominio gratuitos, en los que confían los principales navegadores.

TLS: AUTORIDAD DE CERTIFICACIÓN (CA)

- Para aplicaciones internas, se puede utilizar una CA interna.
- Esto significa que el FQDN del certificado no se expondrá (ni a una CA externa ni públicamente en las listas de transparencia de certificados).
- Sin embargo, el certificado solo será de confianza para los usuarios que hayan importado y hayan confiado en el certificado de CA interno que se utilizó para firmarlos.

TLS: APLICACIONES

- Usar TLS para todas las páginas
- TLS debe usarse para todas las páginas, no solo para aquellas que se consideran confidenciales, como la página de inicio de sesión.
- Si hay páginas que no imponen el uso de TLS, estas podrían darle al atacante la oportunidad de sniffear información confidencial como tokens de sesión o inyectar JavaScript malicioso en las respuestas para llevar a cabo otros ataques contra el usuario.

TLS: APLICACIONES

- Para las aplicaciones de cara al público, puede ser apropiado hacer que el servidor web escuche las conexiones HTTP no cifradas en el puerto 80 y luego redirigirlas inmediatamente con una redirección permanente (HTTP 301) para brindar una mejor experiencia a los usuarios que escriben manualmente el nombre de dominio.
- Esto debería ser compatible con el encabezado HTTP Strict Transport Security (HSTS) para evitar que accedan al sitio a través de HTTP en el futuro.

TLS: TLS Y NO TLS

- No mezcle contenido TLS y no TLS
- Una página que está disponible a través de TLS no debe incluir ningún archivo de recursos (como JavaScript o CSS) que se carguen a través de HTTP sin cifrar.
- Estos recursos no cifrados podrían permitir que un atacante sniffear las cookies de sesión o inyecte código malicioso en la página.
- Los navegadores modernos también bloquearán los intentos de cargar contenido a través de HTTP no cifrado en páginas seguras.

TLS: TLS Y NO TLS

Conexión del navegador:

[Más información](#)

- ☒ Usar siempre https
☐ No usar siempre https

Navegación segura

☐ Usar Facebook a través de una conexión segura siempre que sea posible.

Guardar cambios

Cancelar

- Opción disponible hasta 2014

TLS: COOKIES "SEGURAS"

- Utilice la flag de cookies "secure"
- Todas las cookies deben estar marcadas con el atributo "secure", que indica al navegador que las envíe solo a través de conexiones HTTPS cifradas, para evitar que sean rastreadas desde una conexión HTTP no cifrada.
- Esto es importante incluso si el sitio web no escucha en HTTP (puerto 80), ya que un atacante que realiza un ataque de MITM podría presentar un servidor web falsificado en el puerto 80 al usuario para robar su cookie.
- Ver: https://infosec.mozilla.org/guidelines/web_security#cookies

TLS: CACHÉ DE DATOS CONFIDENCIALES

- Aunque TLS brinda protección de datos mientras están en tránsito, no brinda ninguna protección para los datos una vez que han llegado al sistema solicitante.
- Como tal, esta información puede almacenarse en la memoria caché del navegador del usuario, o por cualquier proxy intermedio que esté configurado para realizar el descifrado TLS.
- Cuando se devuelven datos confidenciales en las respuestas, se deben usar encabezados HTTP para indicar al navegador y a los servidores proxy que no almacenen la información en caché, a fin de evitar que se almacene o se devuelva a otros usuarios.
- Esto se puede lograr configurando los siguientes encabezados HTTP en la respuesta:

```
Cache-Control: no-cache, no-store, must-revalidate  
Pragma: no-cache  
Expires: 0
```


TLS: HSTS

- HTTP Strict Transport Security (también llamado HSTS) es una mejora de seguridad opcional que es especificada por aplicación web mediante el uso de un encabezado de respuesta.
- Una vez que un navegador compatible recibe este encabezado, ese navegador evitará que se envíen comunicaciones a través de HTTP al dominio especificado y, en su lugar, enviará todas las comunicaciones a través de HTTPS.
- La especificación ha sido lanzada y publicada a finales de 2012 como [RFC 6797 \(HTTP Strict Transport Security \(HSTS\)\)](#) por el IETF.

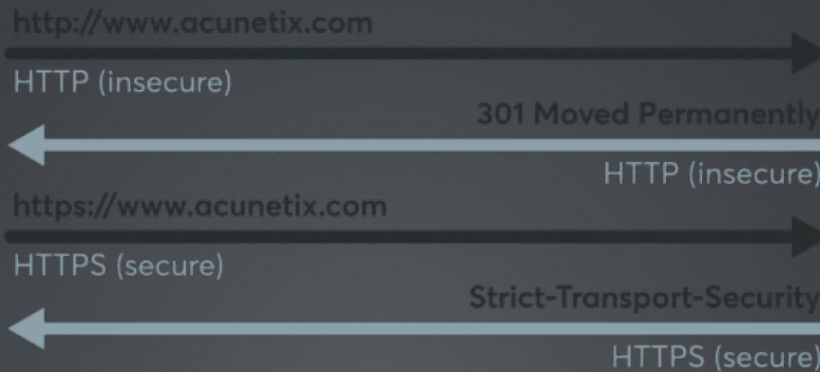


HTTP Strict Transport Security (HSTS)

STEP
1



Client

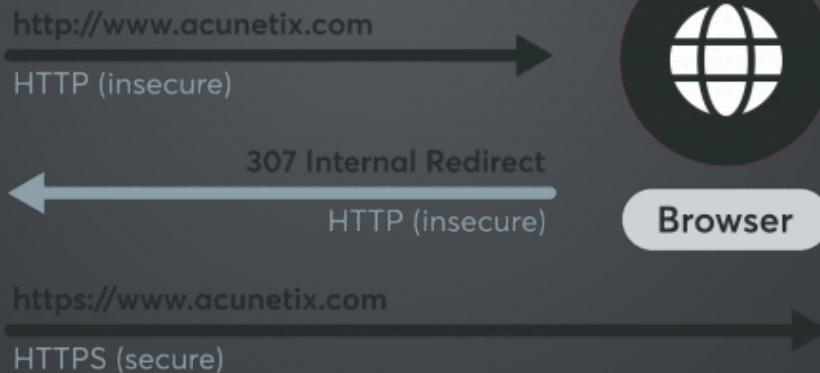


Server

STEP
2



Client



Browser



Server

HSTS: AMENAZAS

- HSTS aborda las siguientes amenazas:
 - Usuario ingresa a <http://example.com> y está sujeto a un atacante man-in-the-middle
 - HSTS redirige automáticamente las solicitudes HTTP a HTTPS para el dominio de destino
 - La aplicación web que está destinada a ser puramente HTTPS contiene inadvertidamente enlaces HTTP o sirve contenido a través de HTTP
 - HSTS redirige automáticamente las solicitudes HTTP a HTTPS para el dominio de destino
 - Un atacante MITM intenta interceptar el tráfico de un usuario víctima utilizando un certificado no válido y espera que el usuario acepte el certificado incorrecto.
 - HSTS no permite que un usuario anule el mensaje de certificado no válido

TLS: HSTS - EJEMPLO

```
Strict-Transport-Security: max-age=<expire-time>; includeSubDomains
```

PROBLEMAS CON TLS DEMOS

- <https://badssl.com>